

SENTINAL SECURITY ASSESSMENT REPORT

Project: Scope: NodeGoat | Type: DAST | Date: 2026-09-04 03:18 UTC

Overall Risk Score	Critical	High	Medium	Low	Total Findings
33.4/100	0	0	3	11	14

1. Executive Summary

****Security Assessment Executive Summary****

****Overall Posture:**** MODERATE POSTURE

The assessment identified 14 security items, mostly of Medium, Low, or Informational severity with no critical remote exploit chains detected.

****Key Risk Highlights:****

- Total Discovered Findings: 14 (Critical: 0, High: 0, Medium: 3, Low: 11)
- Correlated Exploit Chains: 0
- Primary Concern Areas: Session Management

Leadership is advised to authorize immediate sprint allocation for remediation of critical issues and enforce automated security gating in CI/CD pipelines.

3. Findings Inventory

Sev	Source	Vulnerability	Location / Remediation
LOW	DAST	Insecure Cookie Attribute (HttpOnly, Secure, SameSite) on 'AWSALB' The cookie 'AWSALB' is set without the HttpOnly, Secure, SameSite flag(s), allowing potential access via XSS or CSRF.	/ <i>Fix:</i> Add HttpOnly, Secure, SameSite attributes to the Set-Cookie header.
LOW	DAST	Insecure Cookie Attribute (HttpOnly, Secure, SameSite) on 'AWSALB' The cookie 'AWSALB' is set without the HttpOnly, Secure, SameSite flag(s), allowing potential access via XSS or CSRF.	/catalog <i>Fix:</i> Add HttpOnly, Secure, SameSite attributes to the Set-Cookie header.
LOW	DAST	Insecure Cookie Attribute (HttpOnly, Secure, SameSite) on 'AWSALB' The cookie 'AWSALB' is set without the HttpOnly, Secure, SameSite flag(s), allowing potential access via XSS or CSRF.	/blog <i>Fix:</i> Add HttpOnly, Secure, SameSite attributes to the Set-Cookie header.

LOW	DAST	Insecure Cookie Attribute (HttpOnly, Secure, SameSite) on 'AWSALB' The cookie 'AWSALB' is set without the HttpOnly, Secure, SameSite flag(s), allowing potential access via XSS or CSRF.	/about <i>Fix:</i> Add HttpOnly, Secure, SameSite attributes to the Set-Cookie header.
LOW	DAST	Insecure Cookie Attribute (HttpOnly, Secure, SameSite) on 'AWSALB' The cookie 'AWSALB' is set without the HttpOnly, Secure, SameSite flag(s), allowing potential access via XSS or CSRF.	/my-account <i>Fix:</i> Add HttpOnly, Secure, SameSite attributes to the Set-Cookie header.
LOW	DAST	Insecure Cookie Attribute (HttpOnly, Secure, SameSite) on 'AWSALB' The cookie 'AWSALB' is set without the HttpOnly, Secure, SameSite flag(s), allowing potential access via XSS or CSRF.	/login <i>Fix:</i> Add HttpOnly, Secure, SameSite attributes to the Set-Cookie header.
LOW	DAST	Insecure Cookie Attribute (HttpOnly, Secure, SameSite) on 'AWSALB' The cookie 'AWSALB' is set without the HttpOnly, Secure, SameSite flag(s), allowing potential access via XSS or CSRF.	/catalog/cart <i>Fix:</i> Add HttpOnly, Secure, SameSite attributes to the Set-Cookie header.
LOW	DAST	Insecure Cookie Attribute (HttpOnly, Secure, SameSite) on 'AWSALB' The cookie 'AWSALB' is set without the HttpOnly, Secure, SameSite flag(s), allowing potential access via XSS or CSRF.	/catalog/product <i>Fix:</i> Add HttpOnly, Secure, SameSite attributes to the Set-Cookie header.
LOW	DAST	Insecure Cookie Attribute (HttpOnly, Secure, SameSite) on 'AWSALB' The cookie 'AWSALB' is set without the HttpOnly, Secure, SameSite flag(s), allowing potential access via XSS or CSRF.	/catalog/product/stock <i>Fix:</i> Add HttpOnly, Secure, SameSite attributes to the Set-Cookie header.
MEDIUM	DAST	Missing Clickjacking Defense (X-Frame-Options / CSP frame-ancestors) The target web page does not enforce frame embedding restrictions, leaving users vulnerable to UI redressing (Clickjacki	/catalog/product/stock <i>Fix:</i> Set `X-Frame-Options: DENY` or `Content-Security-Policy: frame-ancestors 'none'`.
MEDIUM	WEB	Missing HTTP Strict Transport Security (HSTS) Header The HSTS header forces web browsers to communicate exclusively over encrypted HTTPS, mitigating SSL-stripping and man-in	/ <i>Fix:</i> Add `Strict-Transport-Security: max-age=31536000; includeSubDomains; preload` header to all HTTPS re

MEDIUM	WEB	Missing Content Security Policy (CSP) Header A Content Security Policy restricts sources of executable scripts, stylesheets, and frames, preventing Cross-Site Script	/ <i>Fix:</i> Implement a strong `Content-Security-Policy` header (e.g. `default-src 'self'; script-src 'self'; ob
LOW	WEB	Missing X-Content-Type-Options Header Setting `X-Content-Type-Options: nosniff` prevents browsers from MIME-sniffing a response away from the declared content	/ <i>Fix:</i> Configure `Permissions-Policy: camera=(), microphone=(), geolocation=()` to disable unused browser A
LOW	WEB	Missing Referrer-Policy Header The Referrer-Policy header controls how much referrer information (sent via the Referer header) should be included with	/ <i>Fix:</i> Configure `Referrer-Policy: strict-origin-when-cross-origin` or `no-referrer`.